Cyber Liability Gallagher Application Form

UK/ROW

Gallagher

Insurance | Risk Management | Consulting

1	COMPANY DETAILS	
1.1	Name & Subsidiaries	
1.2	Location (List all countries you operate in/you have operations in/stores in):	
1.3	Website	
1.4	Industry	
1.5	Business Description	
1.6	Date Established	

2	FINANCIALS			
		Last complete financial year	Current year (estimated)	Next year (estimated)
2.1	Gross Annual Revenue			
2.2	Annual Net Income before Taxes			
2.3	Split in Revenue clients subject to USA law			
2.4	Split in Revenue clients subject to European/Canadian/Australian law			
2.5	Split in Revenue clients subject to other law			
2.6	% of annual transactions paid for by debit/credit card			%
2.7	% of yearly budget allocated to IT			%
2.8	Current number of employees			
2.9	Have you been involved in any mergers/ acquisitions within the last three years? If so, were systems integrated?			

3	CLAIMS HISTORY
3.1	Within the last five years have you sustained any systems intrusion, tampering, virus or malicious code attack, loss of data, loss of portable media, hacking incident, extortion attempts, data theft or similar? (If yes, please provide details)
3.2	Within the last five years have you received any claims or complaints with respect to allegations of invasion of or injury to privacy, identity theft, theft of information, breach of information security, content infringement or been required to provide notification to individuals due to an actual or suspected disclosure of personal information? (If yes, please provide details)
3.3	Within the last five years have you ever been subject to any government action, investigation or subpoena regarding any alleged violation of any privacy/data security law or regulation? (If yes, please provide details)

© 2020 Arthur J. Gallagher & Co.

3.4	Do you, or any director, officer, employee or other proposed insured have knowledge or information of any fact, circumstance, situation, event or transaction which may give rise to a claim or privacy breach notification under the proposed insurance? (If yes, please provide details)
3.5	In light of any incident please provide details of any repeat attacks and remediation work that has been undertaken as a result:

4 DATA ASSESSMENT

Please identify type of information you store (please estimate number of each):

4.1	Personally Identifiable Information		4.2	Driver's License Numbers	
4.3	National Insurance Numbers		4.4	Healthcare Information	
4.5	Credit Card Information		4.6	Financial Information	
4.7	Personal Information e.g. Religion		4.8	Other (please specify)	

4.9	Do you store any 3rd Party Trade Secrets/Corporate Information?	Yes ☐	No ☐
		Comments referenced in the appendix	
4.10	If you act as a data processor, please estimate number of processed records		
4.11	Estimate number of individual personally identifiable records currently stored within your owned network		
4.12	Estimate number of individual personally identifiable records currently stored within third party networks on your behalf		
4.13	Are the results of these inventories provided to your organization's risk management function to scope, assess, and mitigate the risk to the assets using a commonly accepted risk	Yes ☐	No ☐

5 DATA ASSESSMENT

5.1	Do you have a Data Protection Officer or someone in charge of Information Security?	Yes ☐	No ☐
5.2	Are background checks of all employees carried out as part of the hiring process?	Yes ☐	No ☐
5.3	Do you mandate Information Security training covering topics such as acceptable use of information systems, malware and ransomware threats, password protection, and safe web browsing and email practices on a recurring basis for all employees?	Yes ☐	No ☐
5.4	Are all employees required to evidence that they understand your privacy policy including use of your network?	Yes ☐	No ☐
5.5	Do you have an identity theft program in place which provides an avenue for all employees to report suspected activity of colleagues?	Yes ☐	No ☐
5.6	Is user access based on an employee's job function and reviewed on at least an annual basis for suitability?	Yes ☐	No ☐
5.7	Are all users forced to change passwords on at least a quarterly basis and instructed to use at least six characters with a combination of lowercase, uppercase, digits and symbols?	Yes ☐	No ☐
5.8	Is access immediately terminated following both friendly and hostile departures?	Yes ☐	No ☐
5.9	Have you terminated the contract of any IT staff in the last 12 months?	Yes ☐	No ☐
5.10	If yes, were any of these decisions made as a result of malicious or dishonest actions?	Yes ☐	No ☐

© 2020 Arthur J. Gallagher & Co.

5.11	If yes, please provide more information:		

6 NETWORK ASSESSMENT

6.1	Has your network been externally assessed/penetration tested in the last year?	Yes ☐	No ☐
6.2	Has your network been internally assessed/penetration tested in the last year?	Yes ☐	No ☐
6.3	Have all critical recommendations been implemented?	Yes ☐	No ☐
6.4	If all critical recommendations have not been implemented, please provide details of actions to be taken with deadlines:		

7 PHYSICAL SECURITY

7.1	Are there physical security measures in place for access to your data centres/server rooms i.e. 24 Hour Security/Access Cards and Biometric Access?	Yes ☐	No ☐
7.2	Do you enforce a clear desk policy at all your sites?	Yes ☐	No ☐
7.3	Do you have a data retention & destruction policy?	Yes ☐	No ☐

8 SYSTEM SECURITY

8.1	Are firewalls in place at all external connection points?	Yes ☐	No ☐
8.2	Do you review firewall rules, configurations and settings on at least a quarterly basis?	Yes ☐	No ☐
8.3	Do you run anti-virus on your network including on all incoming traffic?	Yes ☐	No ☐
8.4	Do you regularly conduct vulnerability scans to detect assets that don't conform to approved configurations management protocols or that are out of patch?	Yes ☐	No ☐
8.5	In what time frame will critical patches be implemented?	24 hours ☐	
		72 hours ☐	
		Week ☐	
	Other		
	Do you have Intrusion Prevention, Detection or Data Loss Prevention software deployed on your:		
8.6	Workstations?	Yes ☐	No ☐

© 2020 Arthur J. Gallagher & Co.

8.7	Laptops?	Yes ☐	No ☐
8.8	How often are intrusion logs reviewed/monitored?	Daily ☐	
		Weekly ☐	
		Fortnightly ☐	
	Other		
8.9	What is the response process/escalation for intrusion alerts?		
8.10	What is the expected response time for a critical alert?		
8.11	Where software is developed internally or modified, are information security measures built in?	Yes ☐	No ☐
8.12	Do you complete penetration testing and a code review on all new systems/software before deployment?	Yes ☐	No ☐
8.13	What is the approximate number of servers on your network?		
8.14	At how many locations are servers located?		
8.15	Please provide an approximate number of external IP addresses on your network		
8.16	Do you segment your network in such a way that sensitive or high-risk assets reside on network segments that are separate from general use assets?	Yes ☐	No ☐
8.17	Do you control access to sensitive assets on a 'least-privilege' basis using a request and authorization process, followed by a separate enablement process?	Yes ☐	No ☐

9 CRITICAL DATA

9.1	Are your networks and systems segregated as opposed to all residing on a flat network?	Yes ☐	No ☐
9.2	Do you segregate critical data in an isolated environment?	Yes ☐	No ☐
9,3	Do you focus your IT spend and protection on critical data?	Yes ☐	No ☐
9.4	Is this critical data encrypted at rest?	Yes ☐	No ☐
9.5	Are additional security measures such as tokenisation or salting used where applicable?	Yes ☐	No ☐
9.6	If yes, please provide details		
9.7	How often is non-relevant critical data permanently deleted?		
9.8	Please estimate maximum number of personally identifiable records currently residing on any one server or centralised location:		

© 2020 Arthur J. Gallagher & Co.

10	REMOTE ACCESS		
10.1	Do you allow remote access to your corporate network?	Yes ☐	No ☐
10.2	If yes, do you limit to two–factor authentication only?	Yes ☐	No ☐
10.3	Are all connecting devices required to have anti-virus and firewall installed in accordance with your company policy for updates and patching?	Yes ☐	No ☐
10.4	Have you conducted an inventory of all authorized and unauthorized devices and software using an automated discovery and inventory tool?	Yes ☐	No ☐
10.5	Do you require external partners who will access your information systems or will house or process your data to accept contract provisions governing: data destruction; incident notification; hiring practices for those who will have access?	Yes ☐	No ☐

11	PORTABLE DATA		
11.1	Do you encrypt all sensitive data that is physically removed from your premises by laptop, mobile / portable devices, USB or other means?	Yes ☐	No ☐
11.2	If no, to above do you store sensitive data on such devices?	Yes ☐	No ☐
11.3	Do you allow Bring-Your-Own-Device?	Yes ☐	No ☐
11.4	If yes, to above do you have a policy that governs usage and controls?	Yes ☐	No ☐
11.5	Do you use a Mobile Device Management system which gives the ability to remote wipe the devices?	Yes ☐	No ☐
11.6	Do you have processes and policies in place that outline what happens if a personal device with corporate data is lost or stolen?	Yes ☐	No ☐
11.7	Is there additional training for personnel using mobile computing to raise their awareness on additional risks?	Yes ☐	No ☐
11.8	Is sensitive data encrypted when sent outside your network (in transit)?	Yes ☐	No ☐
11.9	Do you export your data to other jurisdictions?	Yes ☐	No ☐
11.10	Are you aware of all legal and regulatory requirements of above jurisdictions in relation to Privacy and Data Security?	Yes ☐	No ☐

12	RISK MANAGEMENT PROCEDURES		
12.1	Do you have procedures in place that govern Risk Management?	Yes ☐	No ☐
12.2	Does your organization have specific assigned roles responsible for overseeing the implementation of information security policies and procedures according to an established?	Yes ☐	No ☐
12.3	Do you have a dedicated technical team responsible for configuring IT Security measures?	Yes ☐	No ☐
12.4	Do managers ensure that the requirements and criteria for acceptance of new systems are clearly defined, agreed, documented, and tested?	Yes ☐	No ☐
12.5	Is your vulnerability management process regularly reviewed?	Yes ☐	No ☐
12.6	Are logs maintained that record all changes to information systems?	Yes ☐	No ☐
12.7	Do you allocate Risk Ratings/Business Impacts to your key systems/applications/assets?	Yes ☐	No ☐
12.8	Do you have data classification/categorisation measures in place?	Yes ☐	No ☐
12.9	Has your organization formally adopted an incident response process that includes criteria for investigating possible incidents based on indicators detected through systems?	Yes ☐	No ☐
12.10	Are roles within the plan clearly laid out with backup personnel in place for each key role?	Yes ☐	No ☐
12.11	Do you monitor for compliance and assess the adequacy of your information security plans and policies using any specific frameworks?	Yes ☐	No ☐
12.12	Do your change management policies and procedures ensure that all changes go through a test phase in a test environment and are vetted by stakeholders before entering production?	Yes ☐	No ☐
12.13	Are business methodologies and processes reviewed to ensure that information security is taken into account?	Yes ☐	No ☐

© 2020 Arthur J. Gallagher & Co.

12.14	Are threat landscapes and information security risks assessed and any significant changes identified and communicated?	Yes ☐	No ☐
12.15	Is your organisation's approach to managing information security and its implementation reviewed independently at planned intervals i.e. ISO27001/SSAE 16 SOC 2 etc.	Yes ☐	No ☐
12.16	If yes, please confirm the standards you work to?		

13 VENDOR MANAGEMENT

	Please identify all critical vendors and the service they provide			
13.1	Managed security services (e.g. firewall, intrusion detection, anti virus)			
13.2	Cloud/back up/website hosting			
13.3	Internet Service Providers			
13.4	Business Critical Software Providers			
13.5	Data processors (e.g. payment processing)			
13.6	Point of sale hardware providers			
13.7	Colocation Services			
13.8	Are vendors contractually required to defend and indemnify you if they contribute to a confidentiality or privacy breach?		Yes ☐	No ☐
	If no, please provide details of the procedures in place with respect to third party indemnification arising from Insured's legal liability from a third party loss, release or disclosure of confidential information:			
13.9	Are vendors audited to ensure they meet your security standards?		Yes ☐	No ☐
	If no, what due diligence is carried out prior to contracting with a vendor?			
13.10	Are vendors/sub-contractors credentials captured and retained?		Yes ☐	No ☐
13.11	Do you restrict vendors/sub-contractors access to relevant data only to the role they are performing?		Yes ☐	No ☐
13.12	Is their access limited to working hours only?		Yes ☐	No ☐
13.13	Is their access limited to the duration of the contract?		Yes ☐	No ☐
13.14	How often are their access rights reviewed?		Monthly ☐	
			Quarterly ☐	
			Annually ☐	

© 2020 Arthur J. Gallagher & Co.

	Other	
13.15	How often are their contracts reviewed?	Quarterly ☐
		Annually ☐
		Start of Contract only ☐

14 LEGAL/REGULATORY

14.1	Do you have a privacy policy?	Yes ☐	No ☐
14.2	Is the privacy policy on your website?	Yes ☐	No ☐
14.3	Is the policy approved by your board or legal department?	Yes ☐	No ☐
14.4	Is the policy reviewed on at least an annual basis?	Yes ☐	No ☐
14.5	Do you require this policy to be strictly adhered to?	Yes ☐	No ☐
14.6	Do you have a written, Board approved corporate policy that addresses compliance with the privacy and security laws or regulations noted below as required for your business/industry or required by jurisdiction where you conducts business: (Tick all that apply)		

	Californian Do Not Track laws? (Only California residents)	Yes ☐	No ☐	N/A ☐
	Identity Theft Prevention program (i.e. FTC "Red Flags" programme)	Yes ☐	No ☐	N/A ☐
	Gramm-Leach Bliley Act 1999	Yes ☐	No ☐	N/A ☐
	Sarbanes-Oxley	Yes ☐	No ☐	N/A ☐
	HIPPA/ HITECH	Yes ☐	No ☐	N/A ☐
	European Union Data Protection Directive	Yes ☐	No ☐	N/A ☐
	EU-US Safe Harbor Framework Agreement	Yes ☐	No ☐	N/A ☐
	Other (please specify):			

15 SUPPLEMENT A – DATA RECOVERY AND BUSINESS INTERRUPTION

15.1	Do you have a written Disaster Recovery Plan that addresses network outages?	Yes ☐	No ☐
15.2	Is this tested on at least an annual basis?	Yes ☐	No ☐
15.3	Have all recommendations as a result of this been implemented?	Yes ☐	No ☐
15.4	Are copies of this plan kept in a hard copy or soft copy in a secure environment that is accessible in case of a full network outage?	Yes ☐	No ☐
15.5	What is the time taken to fully restore critical systems?	Under 6 hours ☐	
		6-10 hours ☐	
		10-12 hours ☐	
		12-24 hours ☐	
	Other		

© 2020 Arthur J. Gallagher & Co.

15.6	What is the time taken to fully restore non-critical systems?	Under 6 hours	☐
		6-10 hours	☐
		10-12 hours	☐
		12-24 hours	☐
	Other		
15.7	Do you have a manual workaround to mitigate loss in the event of network outage?	Yes ☐	No ☐
15.8	Do you have the ability to fail-over to a hot site in the event your main hosting site goes down (owned or third party)?	Yes ☐	No ☐
	If not a hot site please describe what is in place?		
15.9	Do you/your data hoster use load balancing to ensure that servers are not overloaded?	Yes ☐	No ☐
15.10	Do you take physical back-ups that are stored off-site?	Yes ☐	No ☐
15.11	How frequently are these done?	Daily	☐
		Weekly	☐
		Fortnightly	☐
		Monthly	☐
	Other		
	How long are back-ups retained?		

16 SUPPLEMENT B – CREDIT CARD DATA (ONLY FILL THIS SUPPLEMENT IN IF YOU OPERATE POINT OF SALE SYSTEMS)

16.1	What is your revenue from sales using POS (Point of Sale) Systems?				
16.2	What level of PCI merchant are you?	1 ☐	2 ☐	3 ☐	4 ☐
16.3	When did you last complete a PCI audit?				
16.4	Was this assessed by PCI V3 standard?			Yes ☐	No ☐
16.5	When will your systems be EMV compliant?			Already compliant	☐
				0-3 months	☐
				3-6 months	☐
				6-12 months	☐
	Other				
16.6	Are you in compliance with the credit card number truncation provisions of the Fair and Accurate Credit Transaction Act (FACTA)?			Yes ☐	No ☐
16.7	Is credit card data sent to a payment processor?			Yes ☐	No ☐
16.8	If yes, please provide the name of the payment processor if not already provided:				

© 2020 Arthur J. Gallagher & Co.

16.9	Has the payment processor provided evidence which proves PCI compliance?	Yes ☐	No ☐
16.10	Is credit card information either encrypted (ETEE) or tokenised at all times?	Yes ☐	No ☐
16.11	If no, at what points are data unencrypted and what security protects the credit card information when it is unencrypted?		
16.12	Are POS terminals designed to be tamper-proof?	Yes ☐	No ☐
16.13	Are they regularly checked to ensure that they have not been tampered with?	Yes ☐	No ☐
16.14	Are separate specific vulnerability scans and penetration tests carried out on PoS systems?	Yes ☐	No ☐
16.15	How often do you perform these?		
16.16	What factor authentication is used to access your POS network?		
16.17	Do you use additional security controls such as jump servers, password vaults or access controls to restrict access?	Yes ☐	No ☐
16.18	If yes, please provide details		
16.19	Do you allow vendors to directly access your POS network?	Yes ☐	No ☐
16.20	What specific security controls are in place for vendor access?		
16.21	Are alerts from IDS/IPS and DLP for your POS network monitored 24x7x365?	Yes ☐	No ☐
16.22	Is this running continuously?	Yes ☐	No ☐
16.23	What additional change controls are in place for POS network?		
16.24	What operating system is your POS network built on?		
16.25	If operating on Windows XP, when will this be upgraded?		
16.26	Is it a custom development?	Yes ☐	No ☐
16.27	Do you collect any Personally Identifiable Information at Point-of-Sale?	Yes ☐	No ☐
16.28	Are you compliant with the Song Beverly Act or other similar state laws?	Yes ☐	No ☐

© 2020 Arthur J. Gallagher & Co.

17	SUPPLEMENT C – MULTIMEDIA (ONLY FILL THIS SUPPLEMENT IN IF YOU REQUIRE THIS COVER)				
17.1	Please check all descriptions of website content posted by you, including content posted to social media web pages.	No Website			☐
		Content under license from a third party			☐
		Unlicensed third party content (e.g. – Blog/Message Boards/ Customer Reviews)			☐
		Information created by you			☐
		Streaming video or music content			☐
17.2	Do you have a procedure for responding to allegations that content created, displayed or published by you is libelous, infringing, or in violation of a third party's privacy rights?	Yes	☐	No	☐
17.3	Do you have a process to review all content prior to posting on the Insured's internet site or on social media web pages created and maintained by or on behalf of the Insured?	Yes	☐	No	☐
17.4	If yes, is the review performed by a qualified attorney:	Yes	☐	No	☐
17.5	Does the review include screening the content for the following:	Yes	☐	No	☐
	A. Disparagement issues?	Yes	☐	No	☐
	B. Copywriting infringement?	Yes	☐	No	☐
	C. Trademark infringement?	Yes	☐	No	☐
	D. Invasion of privacy?	Yes	☐	No	☐
17.6	If you do not have a process to review all content prior to posting, please describe procedures to avoid the posting of improper or infringing content:				
17.7	Have you screened all trademarks used by the Applicant for infringement with existing trademarks prior to first use?	Yes	☐	No	☐
17.8	Have you acquired any trademarks from others in the past three (3) years?	Yes	☐	No	☐
17.9	If Yes, were acquired trademarks screened for infringement?	Yes	☐	No	☐

© 2020 Arthur J. Gallagher & Co.

APPENDIX

© 2020 Arthur J. Gallagher & Co.

DECLARATION

We have set out below the applicable duty of disclosure that you have as regards insurers, where your policy is governed by the laws of England, Wales, Scotland, and Northern Ireland.

You are required to make a fair presentation of the risk to Insurers which discloses every material circumstance which you know or ought to know relating to the risk to be insured. A circumstance is material if it would influence the judgment of a prudent insurer in determining whether to provide insurance for the risk and, if so, on what terms.

What you know: You will be expected to know any information which is known by individuals who are: (a) part of your senior management (i.e. individuals who play a significant role in the making of decisions about how your activities are to be managed or organised); (b) responsible for arranging your insurance (i.e. individuals who participate on your behalf in the process of procuring your insurance in any capacity).

What you ought to know: In addition, you are expected to know any information that should reasonably have been revealed by a reasonable search of information available to you (whether the search is conducted by making enquiries or by other means). This could include any information held within your organisation or by any other person.

Clear and Accessible disclosure: The disclosure you give must be made in a manner which would be reasonably clear and accessible to a prudent insurer.

Every material representation of a matter of fact which you make must be substantially correct and every material representation as to a matter of expectation or belief must be made in good faith.

Failure to comply with the duty of fair presentation could mean that the policy is void or that Insurers are not liable to pay all or part of your claim(s).

If you are in any doubt as to what may constitute a fair presentation, please feel free to contact us and we will endeavour to assist you.

If your policy is not subject to English law you are expected to disclose risk information in accordance with the requirements of the applicable law. In such circumstances we expect you will disclose risk information at least equal to the standard required under English law and where the applicable law requires you to disclose information over and above the level required under English law you will provide such information in accordance with that law.

YOUR NAME			
SIGNED ON BEHALF OF THE APPLICANT BY		POSITION/ TITLE	
		DATE	
PRINT NAME			

Arthur J. Gallagher (UK) Limited is authorised and regulated by the Financial Conduct Authority.
Registered Office: The Walbrook Building, 25 Walbrook, London EC4N 8AW. Registered in England and Wales.
Company Number: 1193013. GS05-2020 Exp. 20.02.2021

ARTUK-1410

Gallagher
Insurance | Risk Management | Consulting